

SOC Incident Investigation Report

Repeated Failed Windows Logins

Prepared by Noki Shohid | Cybersecurity Portfolio Project

Incident Type	Repeated failed Windows authentication attempts
Environment	Authorized Windows 11 lab
Detection Source	Windows Security Event Logs ingested into Splunk Enterprise
Primary Event	Windows Security Event ID 4625 - An account failed to log on
Test Account	SOC_TEST
Detection Threshold	5 or more failed logins within a 5-minute window
Assessment	Authorized test activity; behavior is representative of password-guessing detection logic

Executive Summary

This investigation examined repeated failed Windows login attempts generated in an authorized lab environment. Windows recorded the activity as Security Event ID 4625, and the events were ingested into Splunk Enterprise for analysis. A threshold-based SPL detection was used to identify five or more failed logins within a five-minute period. The activity was intentionally generated for testing, but the same pattern in a production environment could indicate password guessing or brute-force activity.

Environment and Tools

- Windows 11
- Windows Security Event Logs
- Sysmon
- Splunk Enterprise
- PowerShell
- MITRE ATT&CK framework

Detection

The investigation focused on Windows Security Event ID 4625, which records a failed logon attempt. The following SPL query was used as the core detection logic:

```

index=soc_lab EventCode=4625
| bin _time span=5m
| stats count by _time host
| where count >= 5

```

Detection logic in plain language: group failed logon events into five-minute windows, count them by host, and return only windows with five or more failures.

Findings

- Repeated failed authentication events were successfully generated against the test account SOC_TEST.
- Windows Security Event ID 4625 provided the authentication-failure evidence used for the investigation.
- Splunk successfully returned repeated failed-login activity that met the configured threshold.
- The lab activity was authorized and intentionally generated; therefore, no real compromise occurred.
- In a production environment, the same pattern would require further review of the affected account, host, timestamps, source information, logon type, and failure reason.

Evidence

The GitHub repository contains the following supporting evidence screenshots:

- 01-windows-lab-environment.jpg - Windows lab environment
- 02-sysmon-running.jpg - Sysmon running
- 03-logon-auditing-enabled.jpg - Windows logon auditing configuration
- 04-splunk-home.jpg - Splunk Enterprise environment
- 05-sysmon-events-in-splunk.jpg - Sysmon events visible in Splunk
- 06-windows-event-4625.jpg - Windows failed-logon event evidence
- 07-splunk-failed-logins.jpg - Failed-login events in Splunk
- 08-splunk-detection-query.jpg - SPL detection query
- 09-splunk-alert.jpg - Splunk alert
- 10-soc-dashboard.jpg - SOC authentication dashboard
- 11-mitre-t1110-001.jpg - MITRE ATT&CK mapping
- 12-detection-validation.jpg - Detection validation evidence

MITRE ATT&CK Mapping

Category	Mapping
Tactic	Credential Access
Technique	T1110 - Brute Force
Sub-technique	T1110.001 - Password Guessing

Risk Assessment

Repeated authentication failures can indicate an attempt to guess credentials. If an attacker successfully obtains valid credentials, the result could include unauthorized access, account misuse, lateral movement, or access to sensitive systems. Because this activity was generated in an authorized lab, the observed event itself was not a real security incident.

Remediation Recommendations

- Enable multi-factor authentication where supported.
- Enforce strong password and account lockout policies.
- Monitor repeated authentication failures in the SIEM.
- Investigate unusual source addresses and authentication patterns.
- Restrict unnecessary remote access paths.
- Review privileged and inactive accounts regularly.
- Tune alert thresholds to reduce false positives while preserving useful detection coverage.

Validation

The detection was validated by generating repeated failed login attempts in the authorized Windows lab and confirming that Splunk identified activity meeting the threshold of five or more failed logons within a five-minute window. The resulting Windows events, Splunk search output, alert, dashboard, and validation screenshot provide supporting evidence that the detection logic functioned as intended.

Lessons Learned

This project demonstrated that detection is only one part of the SOC workflow. A useful investigation also requires evidence review, contextual analysis, risk assessment, MITRE ATT&CK mapping, remediation planning, and validation. A future improvement would be to enrich the SPL query with the actual username, source IP address, logon type, and failure-reason fields available in the environment so the detection provides more actionable triage context.

Conclusion

The lab successfully demonstrated an end-to-end SOC investigation workflow: Windows authentication activity was generated, collected, detected in Splunk, investigated, mapped to MITRE ATT&CK, documented, and validated. All activity was performed in an authorized personal lab for educational and portfolio purposes.